EQUIPO 2 · RETO SOC SAMPOL · DATOS A 04/11/2026 09:28 (HORA DE MADRID)

Informe Hackapol SOC

Una intrusión ha saltado de cuenta en cuenta: 12 cuentas *moreno en 12 equipos de 6 sedes, todas en fase de impacto. El director confirma ransomware con doble extorsión, 18 GB enviados fuera, copias debilitadas y un pago manipulado. Aquí está lo que puede costar, quién está comprometido y qué hemos hecho.

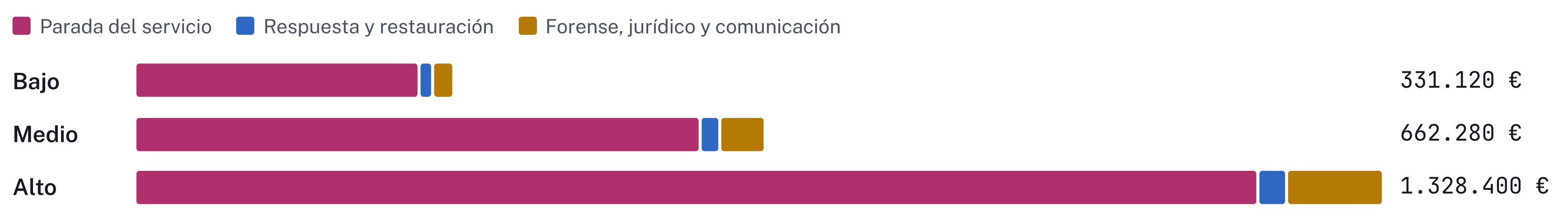
`401` **16 bloqueos en cola y 0 ejecutados por el equipo.** La API de bloqueo rechaza la clave (401) desde la noche del 03/11 y la organización no la repondrá; la causa no está confirmada. La contención real la hizo Infra: a las 5:30 el director informó de que el servidor estaba aislado. Las decisiones del equipo están registradas y justificadas en la base de datos

Demostración (simulador local con el mismo contrato que la API): 13 bloqueos ejecutados y verificados y 1 liberación(es) en un clic. Es una SIMULACIÓN: sin clave válida no hay contención por API; la contención real la hizo Infra (5:30).

257 correos del SOC procesados, clasificados con la taxonomía INCIBE	**12** cuentas comprometidas en 6 sedes (cadena *moreno)
662 k€ coste estimado del incidente (escenario medio)	**280 k€** coste evitable estimado con AUTO-06 (escenario medio; contrafactual, no es ahorro realizado)

Lo que puede costar a la empresa

Origen de cada cifra: `D` dato del director (Excel) · `BD` nuestra base de datos · `H` hipótesis del equipo. La parada del servicio, a 25.000 € por hora `D`, pesa más que todo lo demás junto.



Concepto	Bajo	Medio	Alto	Origen
Horas de parada por sede	2 h	4 h	8 h	`D`
Parada del servicio	300.000 €	600.000 €	1.200.000 €	`D·BD`
Respuesta (analistas)	4.320 €	6.480 €	10.800 €	`H`
Restauración de equipos y servidores	6.800 €	10.800 €	17.600 €	`H`
Forense y asesoría jurídica	15.000 €	30.000 €	60.000 €	`H`
Notificación y comunicación	5.000 €	15.000 €	40.000 €	`H`
Total	**331.120 €**	**662.280 €**	**1.328.400 €**	
Evitable con AUTO-06 (contrafactual)	100.000 €	280.000 €	720.000 €	`BD·H`

Fuera del cálculo, como exposición sin cuantificar: el pago desviado por el documento manipulado (importe desconocido), el rescate (no se recomienda pagar), sanciones del RGPD (hasta 20 M€ o el 4 % de la facturación) y de NIS2 (hasta 10 M€ o el 2 %), y el daño a la reputación.

El SOC manual hoy

29.250 € al mes en revisar alertas y bloquear a mano `D`.

El **52** % de las alertas del buzón llega en guardia de noche (22:00-08:00), la franja más cara y con menos personal `BD`.

Ruido medido: **24,5** % (63 de 257: duplicados, informativos, no SOC y malformados) `BD`; el Excel usa un 63,2 % de ejemplo.

Retorno de la solución

	Excel realista	Ruido real
Inversión inicial	20.000 €	20.000 €
Ahorro neto mensual	5.649 €	3.852 €
Recuperación	3,5 meses	5,2 meses
ROI del primer año	140,9 %	77 %

Hipótesis prudentes del Excel revisado `H`. A 3 años, construir cuesta 61.760 € frente a 216.200 € de un SIEM/SOAR comercial (60.000 €/año + 20.000 € `D`). Las horas liberadas se dedican a investigar.

Bloqueo automático

Escenario	Ahorro + evitado / año	Recuperación	ROI 1.er año
Prudente	4.320 € + 1.440 €	13,3 meses	-6,5 %
Realista	9.504 € + 11.520 €	1,9 meses	355,1 %
Optimista	14.904 € + 51.840 €	0,4 meses	2067,0 %

Análisis forense: las cuentas comprometidas

Una cuenta nueva cada ~74 min, con equipos numerados en orden y sedes en rotación (Barcelona, Bilbao, Madrid, Palma, Sevilla, Valencia). Se alternan dos vías: robo de credenciales (phishing, fuerza bruta, acceso no reconocido) y explotación del equipo (sondeo, explotación, proceso anómalo). En la primera, AUTO-06 detecta el compromiso entre 37 y 55 min antes que la alerta crítica.

🟦 Entrada (reconocimiento, phishing, fuerza bruta) 🟧 Cuenta comprometida, lectura indebida 🟪 Mando y control, ejecución, impacto

#	Cuenta	Equipo · sede	IP	Primer aviso	Fases alcanzadas	Antelación	Bloqueo
1	**jmoreno**	srv-barcelona-201 · Barcelona	203.0.113.150	03/11 14:40	⬜🟦🟦🟧🟧🟪⬜🟪	+39 min	en cola · auto
2	**amoreno**	pc-sevilla-202 · Sevilla	192.0.2.151	03/11 15:33	🟦⬜⬜⬜🟧🟪🟪🟪	–	en cola · auto
3	**cmoreno**	app-valencia-203 · Valencia	198.51.100.152	03/11 16:49	⬜🟦⬜🟧🟧🟪🟪🟪	+41 min	en cola · manual
4	**bmoreno**	gw-bilbao-204 · Bilbao	203.0.113.153	03/11 18:01	⬜🟦🟦🟧🟧🟪⬜🟪	+44 min	en cola · auto
5	**dmoreno**	srv-palma-205 · Palma	192.0.2.154	03/11 19:08	🟦⬜⬜⬜🟧🟪🟪🟪	–	en cola · auto
6	**emoreno**	pc-madrid-206 · Madrid	198.51.100.155	03/11 20:39	⬜🟦⬜🟧🟧🟪🟪🟪	+43 min	en cola · manual
7	**fmoreno**	app-barcelona-207 · Barcelona	203.0.113.156	03/11 21:51	⬜🟦🟦🟧🟧🟪⬜🟪	+46 min	en cola · manual
8	**gmoreno**	gw-sevilla-208 · Sevilla	192.0.2.157	03/11 23:16	🟦⬜⬜⬜🟧🟪🟪🟪	–	en cola · manual
9	**hmoreno**	srv-valencia-209 · Valencia	198.51.100.158	04/11 00:25	⬜🟦⬜🟧🟧🟪🟪🟪	+40 min	en cola · auto
10	**imoreno**	pc-bilbao-210 · Bilbao	203.0.113.159	04/11 01:39	⬜🟦🟦🟧🟧🟪⬜🟪	+55 min	en cola · auto
11	**vmoreno**	app-palma-211 · Palma	192.0.2.160	04/11 02:57	🟦⬜⬜⬜🟧🟪🟪🟪	–	en cola · auto
12	**lmoreno**	gw-madrid-212 · Madrid	198.51.100.161	04/11 04:09	⬜🟦⬜🟧🟧🟪🟪🟪	+37 min	en cola · auto

IPs reconstruidas desde el formato sin puntos del correo (p. ej. 2030113150 → 203.0.113.150). La línea temporal por carriles está en la página Cadena Moreno.

Lo que cuenta el director

- **LAB-FS-01**: archivos `.locked` y nota de rescate (1:05).
- **5:30**: Infra bloquea el ataque y aísla el servidor. Desde entonces no ha aparecido la víctima prevista de la cadena.
- **LAB-WS-17**: sesión activa contra LAB-FS-01; reloj desfasado 11 min.
- **LAB-APP-04**: 18 GB hacia `198.51.100.77`, `auditoria_2026.7z`, tarea «System Health Check» y herramienta remota sin validar.
- **LAB-BKP-02**: retención de copias reducida; la identidad investigada tenía permisos.
- Doble extorsión (descifrado y no publicación). La muestra lleva «Escenario ficticio» y un dominio `.invalid`.
- Documento de pagos con la cuenta de destino cambiada; antecedente en AL-20261030-0121 (jfernandez@).
- Hipótesis de entrada abiertas: soporte remoto no validado, credenciales expuestas o archivo por correo.

Otros casos para revisar

Aviso	Cuenta	Hecho
03/11 10:19	rperez	Uso confirmado de cuenta administrativa desde origen no autorizado `CRITICO`
03/11 10:42	fgomez	Captura de tráfico sin autorización de cambio `ALTO`
03/11 10:43	ggomez	Llamada intenta obtener información del equipo `MEDIO`
03/11 11:04	lgomez	Equipo sustraído de zona restringida `ALTO`
03/11 11:43	rgomez	Datos perdidos tras avería de almacenamiento `ALTO`
03/11 12:07	jfernandez	Suplantación solicita cambio de cuenta de pago `ALTO`
03/11 13:17	hfernandez	Investigación confirma persistencia dirigida en el proyecto `CRITICO`
03/11 17:31	ogonzalez	Captura de tráfico sin autorización de cambio `ALTO`
03/11 21:40	ilopez	Llamada intenta obtener información del equipo `MEDIO`
04/11 03:04	nperez	Datos perdidos tras avería de almacenamiento `ALTO`
04/11 04:27	dgomez	Investigación confirma persistencia dirigida en el proyecto `CRITICO`
04/11 06:28	sfernandez	Investigación confirma persistencia dirigida en el proyecto `CRITICO`
04/11 07:02	prodriguez	Equipo sustraído de zona restringida `ALTO`
04/11 07:22	dgonzalez	Suplantación solicita cambio de cuenta de pago `ALTO`
04/11 07:35	pgonzalez	Uso confirmado de cuenta administrativa desde origen no autorizado `CRITICO`
04/11 08:00	emartinez	Llamada intenta obtener información del equipo `MEDIO`
04/11 08:17	pmartinez	Datos perdidos tras avería de almacenamiento `ALTO`
04/11 08:53	ilopez	Uso confirmado de cuenta administrativa desde origen no autorizado `CRITICO`
04/11 08:58	tlopez	Llamada intenta obtener información del equipo `MEDIO`
04/11 09:05	isanchez	Datos perdidos tras avería de almacenamiento `ALTO`

Accesos no reconocidos sin phishing ni fuerza bruta previos (AUTO-06 no los bloquea; revisión humana): ilopez, mgonzalez, ngonzalez, ogonzalez, osanchez, pgonzalez, sperez.

Qué hicimos

- **Base de datos en Azure (18 migraciones):** bandeja inmutable con huella SHA-256, clasificación INCIBE con 39 reglas explicables, duplicados, inconsistencias y correos manipulados.
- **Autenticidad del remitente** por cabeceras de Exchange (SPF, AuthAs Internal, SHA-256). Las directrices solo valen si vienen de dirti@.
- **Bloqueo automático:** AUTO-05 (crítico verificado) y AUTO-06 (correlación de fases), con lista blanca, liberación humana y cada decisión justificada. AUTO-06: 8 de 12 víctimas detectadas entre 37 y 55 min antes que la alerta crítica, 0 falsos positivos en la simulación sobre el histórico.
- **Investigación:** fases del ataque, cadena de víctimas, predicción de la siguiente y línea temporal para el jurado.
- **Buzón organizado:** 10 carpetas y un flujo de Power Automate que ordena cada correo nuevo sin romper la ingesta.
- **Gestión de crisis:** respuestas al director con plazos de 10 y 20 minutos (acuse y primera respuesta).

Lo que no salió bien

La ficha con credenciales se intentó reenviar a una Gmail desde la cuenta del equipo; después la API rechazó la clave (relación no confirmada).	Credenciales solo en .env y gestor de secretos. Ante una exposición, pedir la rotación por un canal seguro.
0 bloqueos ejecutados: 16 decisiones correctas esperan en cola.	Prever una vía alternativa de contención con registro y una alarma cuando la API devuelve 401.
La extracción de campos estaba rota (usuario «relacionada» en 110 de 110 alertas) hasta la migración 007.	Probar con correos reales desde el principio, no solo con datos sintéticos.
La corroboración contaba los reenvíos como alertas nuevas (falso positivo de slopez, corregido sin llegar a ejecutarse).	Contar por identificador de alerta y probar antes de activar reglas que bloquean.
La ingesta dependía de un cron de GitHub que no se ejecutaba solo.	Ingesta directa desde Power Automate a la BD y alarma de retraso.
El inicio de sesión en Graph falló y no había conexión de PostgreSQL en Power Automate.	Validar antes del evento licencias, conectores y permisos.
En Outlook se pulsó «Copiar» en vez de «Mover» (30 copias).	Confirmar las acciones masivas o automatizarlas de forma revisable.
Plazos de 10 y 20 minutos con el equipo saturado: 2 directrices respondidas fuera de plazo.	Turnos, plantillas de acuse y un responsable de comunicación con dirección.

Próximos pasos

- Rotar la clave de la API por un canal seguro y ejecutar la cola de bloqueos, verificando cada uno.
- Aislar LAB-APP-04, LAB-WS-17 y LAB-FS-01 preservando evidencias; revocar sesiones y credenciales de las cuentas *moreno.
- Restaurar en un entorno aislado desde copias anteriores al compromiso y acordar RTO/RPO por servicio.
- Bloquear 198.51.100.77 y las IPs de la cadena tras revisión humana.
- Verificar con el banco el pago desviado; congelar los cambios en datos de proveedores.
- Jurídico y protección de datos: decidir sobre la notificación (72 h) con hechos verificados.

Fuentes: base de datos del equipo (vistas v_kpis, v_cadena_*, v_decisiones_bloqueo, v_stats_franja), buzón del reto (correos del director) y Analisis_economico_Sampol.xlsx. RGPD art. 83; NIS2 art. 34. Documento completo para PDF: docs/informe/INFORME.md.